RANSOMWARE-CREDENTIAL-THREATS

랜섬웨어·RaaS·인포스틸러·계정 공격

연관 기출 · 128-1-12, 138-4-5, 129-4-1, 131-1-10, 132-1-6

한눈에 이해

파일 암호화 뒤의 복구 문제와 그 전에 빼앗긴 계정·세션·자료 유출을 함께 다룹니다.

정의와 핵심 원리

랜섬웨어는암호화·데이터 탈취·공개 위협등으로피해자를갈취하는악성행위입니다. RaaS는 운영자·제휴공격자등이 도구·인프라·수익분배로역할을나누는서비스형범죄 모델이며 별도 암호 알고리즘이 아닙니다.

• 초기경로는 피싱·노출원격접속·취약점·공급망·도난자격증명등입니다. 공격은 정찰·권한상승·측면이동·정보 탈취·백업훼손·암호화로 이어질수 있지만순서는 사례마다 다릅니다. 대용량파일은대칭암호로 암호화하고 키를 공개 키로 보호하는 등하이브리드구조가 가능합니다.

• 인포스틸러는브라우저비밀번호·쿠키·토큰·지갑등을 탈취하며 세션 토큰은 MFA후세션을 악용할 수 있습니다. 크리덴셜스터핑은타서비스 유출 계정·암호쌍을재사용하고 무차별대입과구분합니다. 큐싱은QR코드로 악성사이트·피싱을 유도하는사회공학입니다.

• 예방은 패치·피싱저항인증·계정 권한·원격노출축소·분리·탐지·오프라인/불변백업·복원 시험입니다. 사고시격리·증거 보존·범위파악·자격증명/세션 회수·신고/통지검토·깨끗한복구·원인 제거·재발평가를 합니다. 복구와 업무연속성·유출 대응을 분리하지 않습니다.

구조·비교·판단

구분	핵심 원리	적용·한계
랜섬웨어	암호화·탈취·갈취	복원·유출·업무 영향
RaaS	도구·인프라·제휴분업	공격 규모·역할분리
인포스틸러/스터핑	비밀탈취/유출쌍재사용	세션 회수·중복 암호 대응

적용 예제

백업이 있어도 필요한 대응

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 파일암호화와 관리자쿠키 탈취의 동시징후

1. 네트워크·계정 접근을 격리하고 증거를 보존합니다.

2. 암호화 범위와 탈취·백업훼손을따로조사합니다.

3. 비밀변경뿐 아니라기존 세션·토큰을 회수합니다.

4. 깨끗한시점 복구후취약원인과 새접근흔적을검증합니다.

결과·해석: 백업 복원완료를사고전체 종결과동일시하지 않습니다.

전제·주의: CISA가 이드직접 접근403으로최신 절차 전문은 미열람.일반 대응 원칙을 NIST포렌식·MITRE 자료로 교차설명했습니다.

답안 골격과 혼동 방지

위협·분업 → 침입과 확산 → 키·데이터갈취 → 예방·대응 흐름 → 복구 검증

- RaaS를SaaS의합법 서비스와 같이취급하지 않습니다.
- MFA사용이면쿠키 탈취에 안전하다고하지 않습니다.

내용을 가리고 회상

1. 랜섬웨어와RaaS의비교축은무엇입니까?

2. 비밀번호 변경만 으로세션 탈취가 끝납니까?

3. 불변백업에도 복원 시험이 필요한 이유는무엇입니까?

적용 기준과 근거

명시한 출처 판본의 원리를 설명하며 제품별 구현 차이는 별도 확인합니다.

내용 검토 상태: 부분 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- MITRE ATT&CK TA0008 Lateral Movement - MITRE; 최종수정 2025-08-11; 확인 2026-11-05.
- NIST SP800-86 Integrating Forensics into Incident Response - Karen Kent et al. / NIST; 2006-08; 확인 2026-11-05.
- NIST SP800-63B-4 Authentication - NIST; 2025-07; 확인 2026-11-05.